

CHALLENGE #8: Ligon Write-up.

logon

Easy

Web Exploitation

picoCTF 2019

AUTHOR: BOBSON

Description

The factory is hiding things from all of its users.
Additional details will be available after launching your challenge instance.

This challenge launches an instance on demand.
Its current status is:
NOT_RUNNING

Launch Instance

Hints

1

90,877 users solved

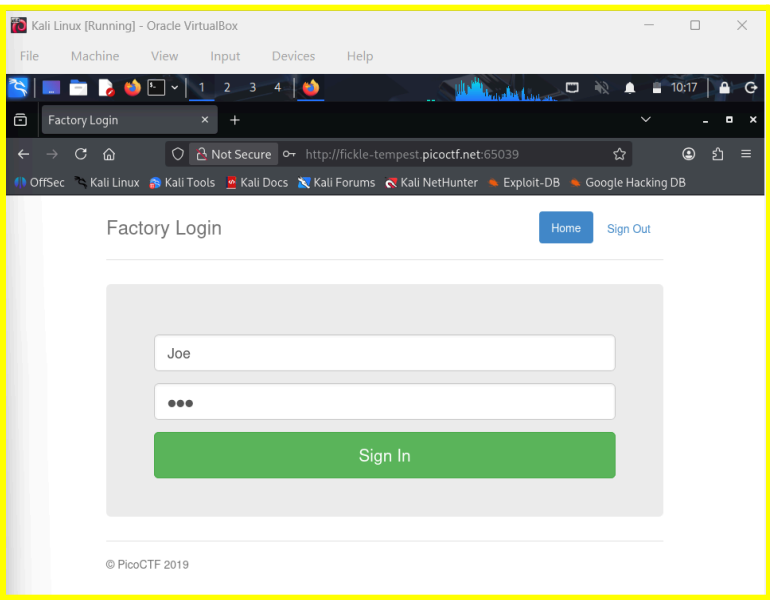
93% Liked

picoCTF{FLAG}

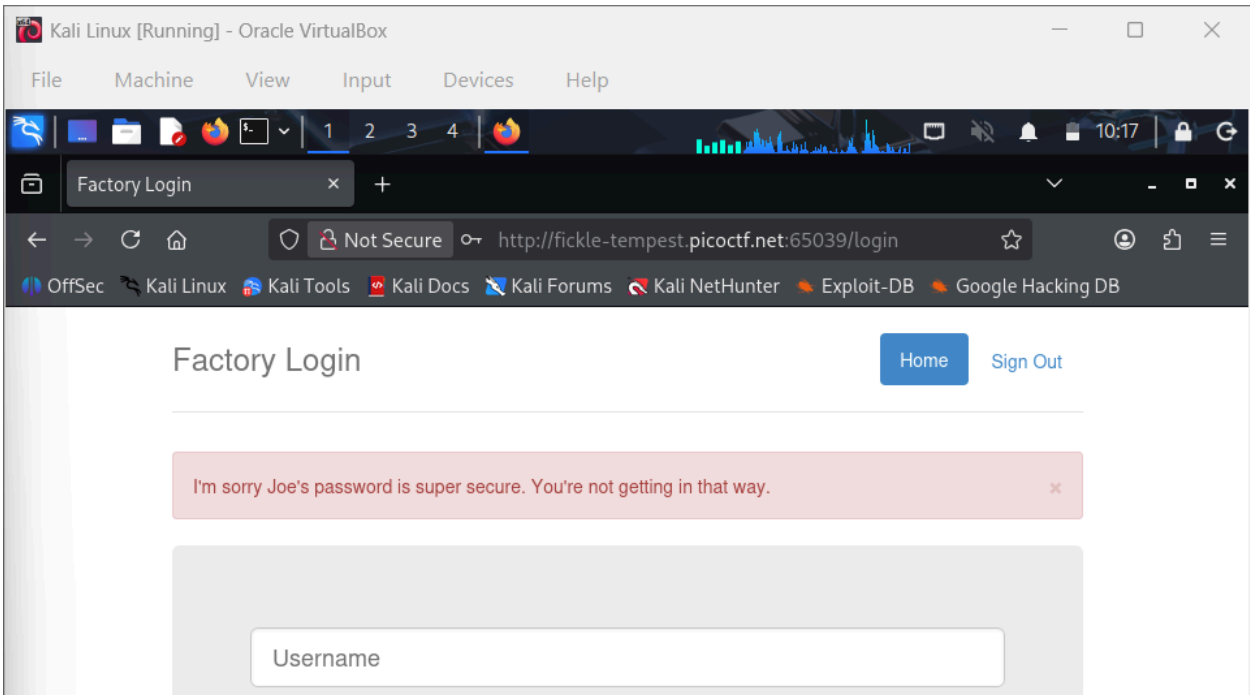
Submit Flag

Solving Process:

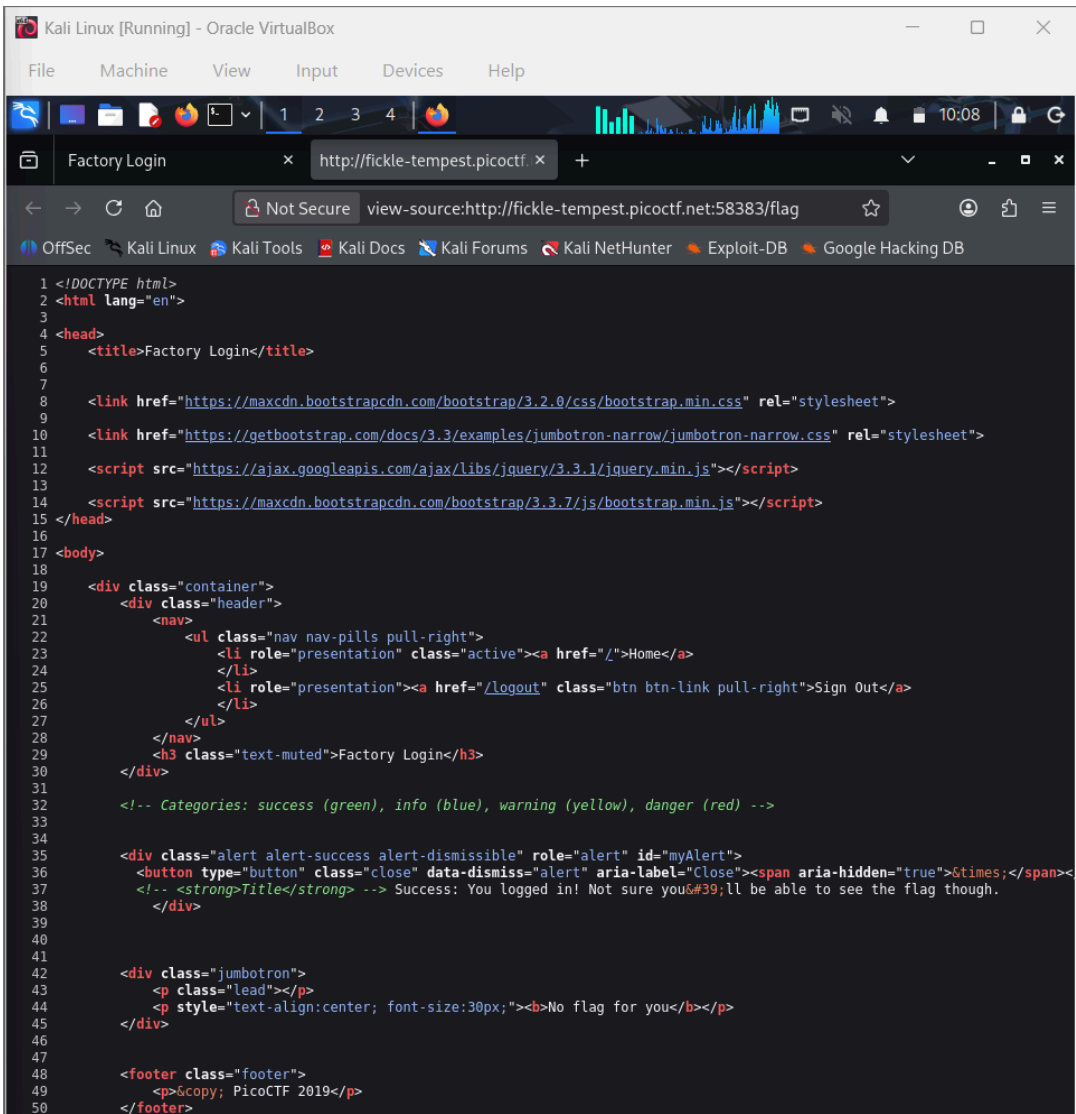
First, the challenge instance was launched and the provided website link was opened in a new browser tab. The website displayed a **login page**, and the goal of the challenge was to bypass the login mechanism in order to retrieve the flag.



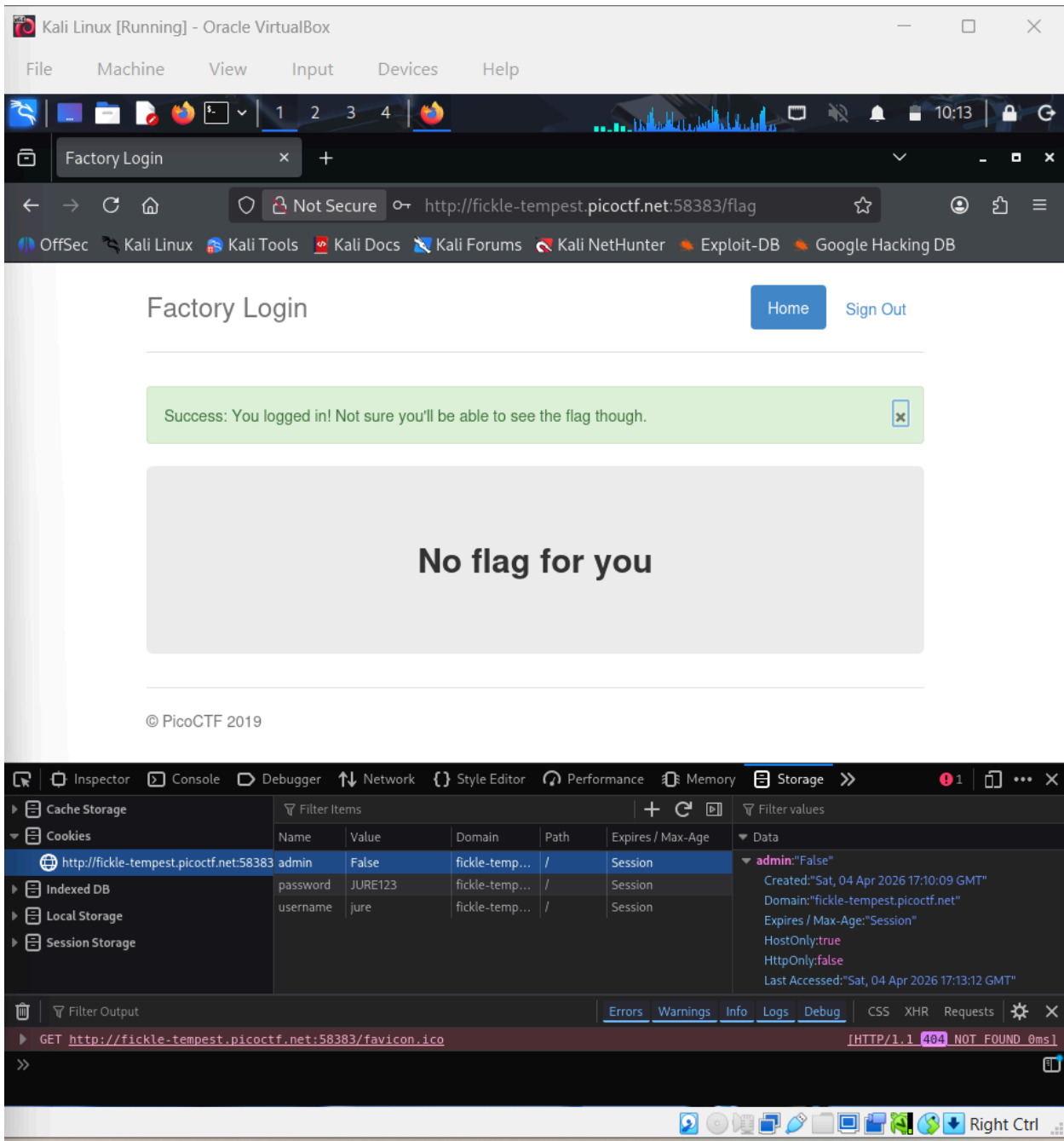
According to the challenge description, the factory was hiding something from its users, and the task was to **log in as Joe** to find out what they were hiding. To begin testing the login form, the username "Joe" and the password "Joe" were entered, and the Sign In button was clicked. However, the login attempt failed, and a message appeared above the login form stating: **"I'm sorry Joe's password is super secure. You're not getting in that way."** This indicated that simply guessing the password would not work.



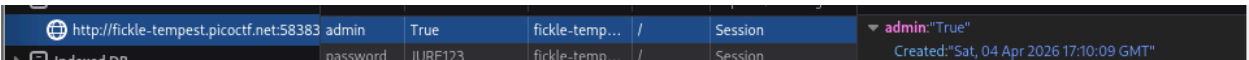
Since direct login attempts were unsuccessful, the next step was to inspect the website for possible clues. The page source was viewed by right-clicking on the page and selecting View Page Source. The HTML code mainly contained basic structure and references to CSS and JavaScript files, but no obvious information about the flag or authentication logic.



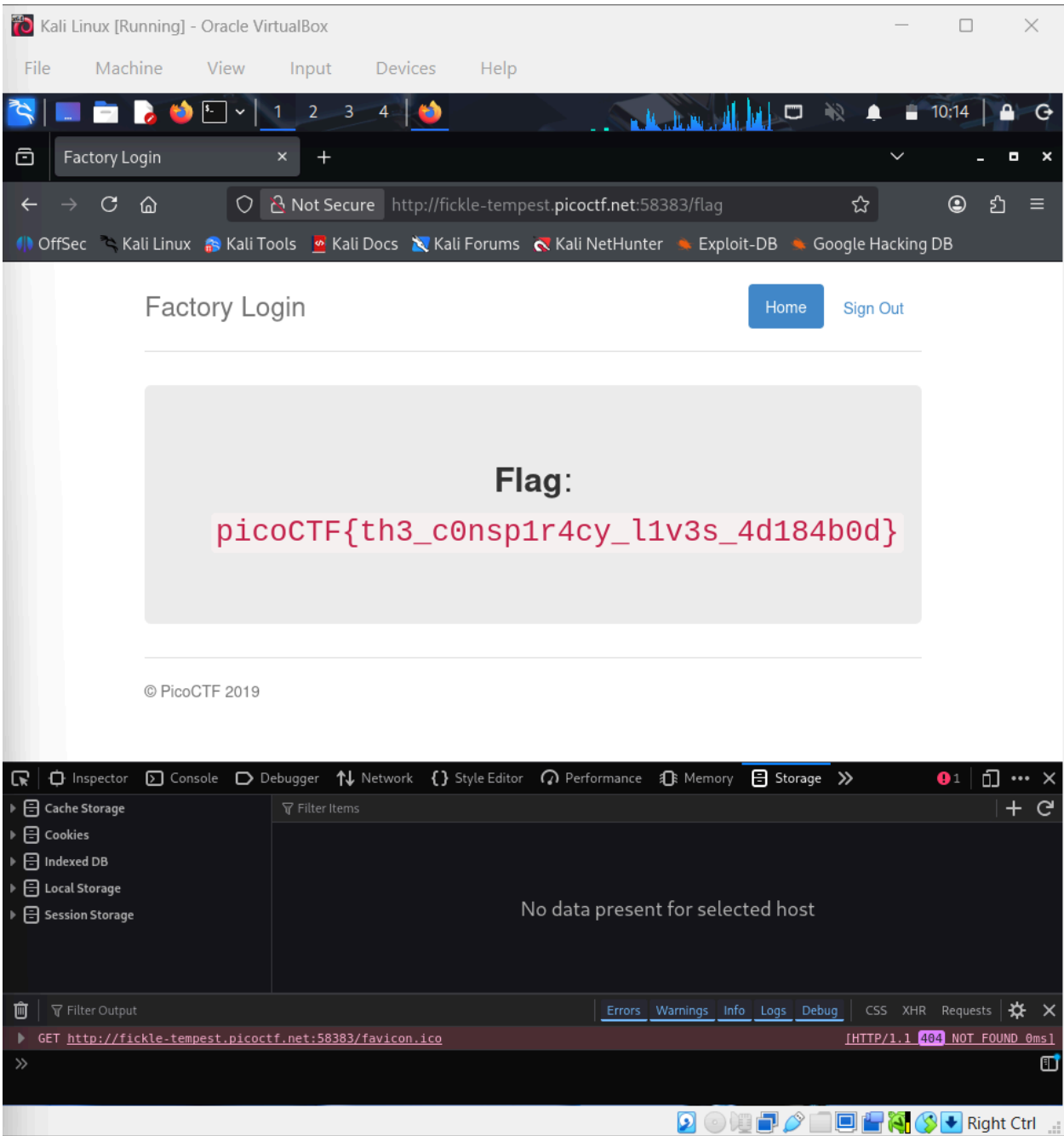
To gain a deeper understanding of the authentication process, I performed a normal login with a test account I created. I then utilized the browser's developer tools to inspect the Storage section, specifically focusing on the Cookies linked to the site. This investigation revealed a cookie named `admin` with its value set to `false`.



This suggested that the website might be using the cookie value to determine whether a user had **administrator privileges**. To test this assumption, the value of the `admin` cookie was manually edited in the browser and changed from `false` to `true`. After modifying the cookie value, the page was refreshed.



Upon reloading the page, the website recognized the modified cookie value and granted administrator-level access, which caused the flag to be displayed. This confirmed that the application was vulnerable to cookie tampering, where altering client-side cookie values could bypass authentication and escalate privileges without proper server-side validation.



login

Easy Web Exploitation picoCTF 2019

AUTHOR: BOBSON

Description

The factory is hiding things from all of its users.
Can you login as Joe and find what they've been looking at?
<http://fickle-tempest.picoctf.net:58383>

Hurray! You solved this challenge.

This challenge launches an instance on demand.
Its current status is: **RUNNING**
Instance Time Remaining: **29:39**

Restart Instance

Hints

1

90,877 users solved



93%
Liked



picoCTF{th3_c0nsp1r4cy_l1v3s_4d184b0d}

Submit
Flag

Reflection:

This challenge showed how client-side cookies should not be trusted for authentication or role verification. By simply modifying the cookie value from false to true, administrative access was granted without properly logging in as the intended user. The activity emphasized the importance of server-side validation and secure role management to prevent attackers from bypassing login controls through cookie tampering.